Hack the Cookie

Date: 5/1/2026
Platform: HackerDNA
URL: https://hackerdna.com/labs/hack-the-cookie

Objective

Manipulate client-side session data (cookies) to escalate privileges and access restricted functionality.

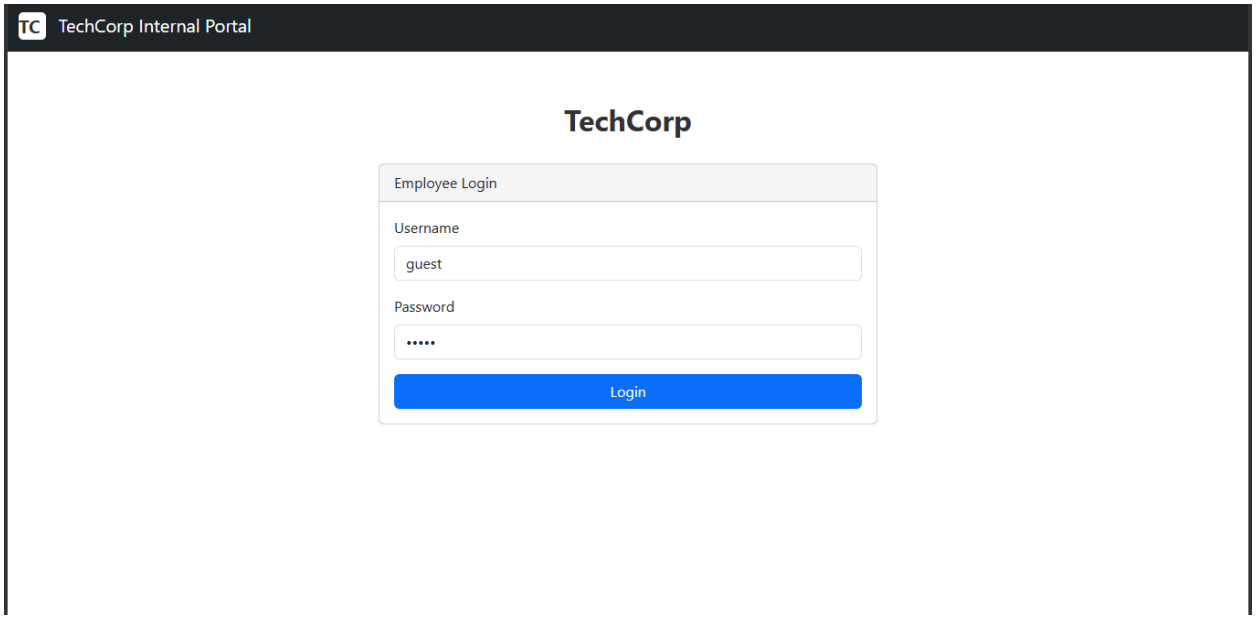
Step 1: Initial Access

Navigated to the provided lab URL:

http://3.249.160.25/

The page loaded a **TechCorp internal portal login**.

Guest credentials were pre-filled, allowing immediate access to the application as a low-privileged user.

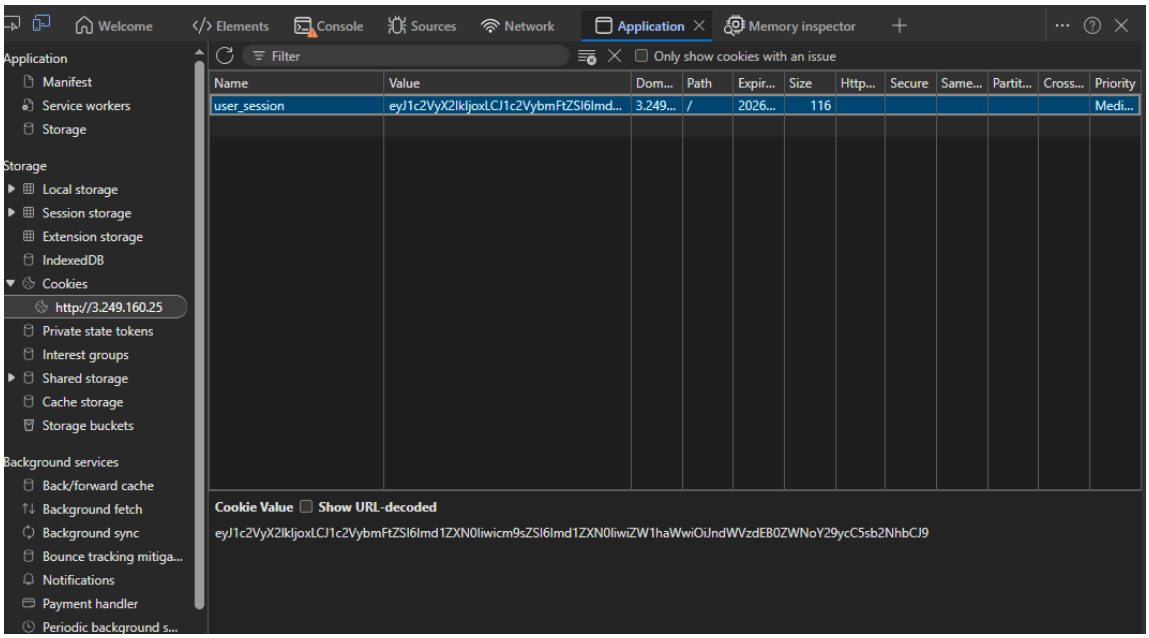


Step 2: Inspect Session Cookie

Opened browser developer tools:

F12 → Application → Cookies

Located the session cookie:



user_session =
eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6Imd1ZXN0Iiwicm9sZSI6Imd1ZXN0IiwiZW1haWwiOiJndWVzdEB0ZWNoY29ycC5sb2NhbCJ9

Step 3: Decode Cookie

The cookie appeared to be **Base64 encoded**.

Decoded using a tool (e.g., Base64 decoder, see attached screenshots):

{"user_id":1,"username":"guest","role":"guest","email":"guest@techcorp.local"}

Issue Identified: Client-Side Authorization

- **User role is stored in the cookie**
- **No integrity protection (no signature / encryption)**
- **The server trusts client-provided role data**

Step 4: Modify Privileges

Edited the decoded JSON with an “admin” role value:

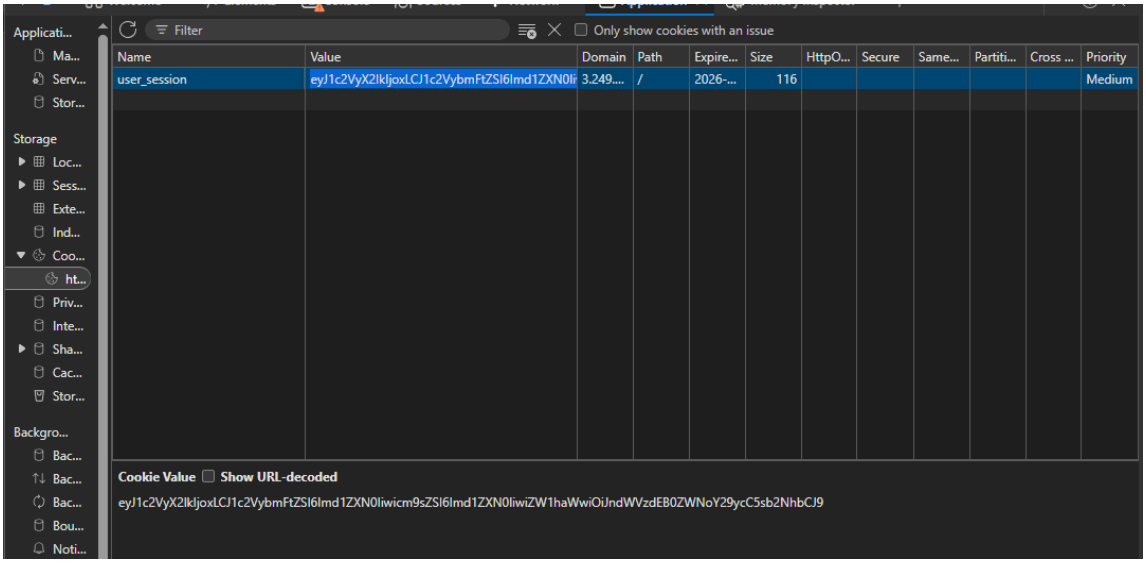
{"user_id":1,"username":"guest","role":"admin","email":"guest@techcorp.local"}

Re-encoded to Base64 (see attached screenshots):

eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6Imd1ZXN0Iiwicm9sZSI6ImFkbWluIiwiZW1haWwiOiJndWVzdEB0ZWNoY29ycC5sb2NhbCJ9

Step 5: Inject Modified Cookie

Replaced the original cookie value in DevTools with new modified cookie:

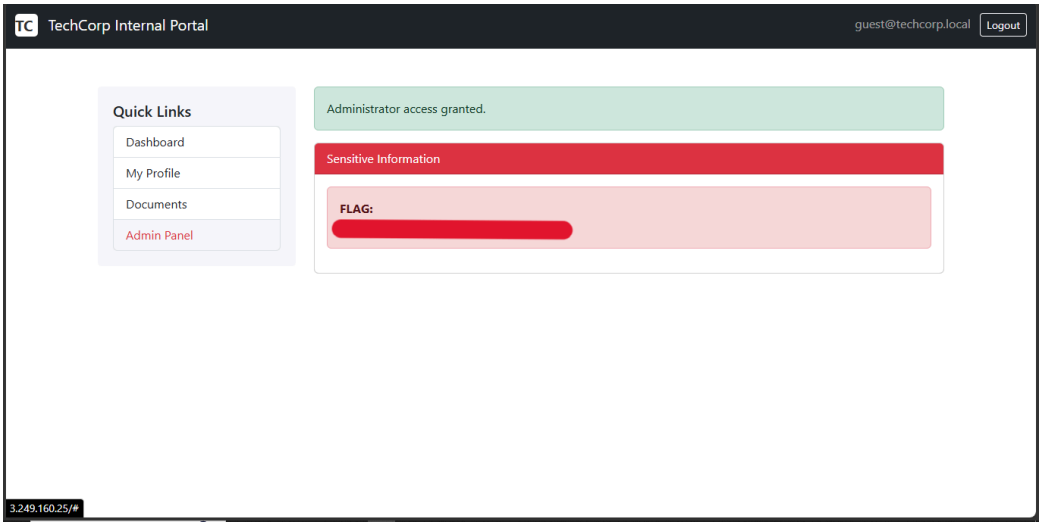


Then refreshed the page to update session data.

Result / Flag

The application recognized the modified session and granted **admin privileges**, exposing an **Admin Panel**.

From there, access to the flag was obtained:



(Flag omitted intentionally for integrity of the challenge)

Key Takeaways:

1. Never trust client-side data for authorization decisions.
2. Cookies should be signed and/or encrypted to prevent tampering.
3. Sensitive fields like "role" should be validated server-side.
4. Base64 is encoding, not security; it provides zero protection.
5. Session integrity is critical for access control.